



Powered by **Arizona State University®**

Alumno: Luis Alberto Vargas González.

Fecha: 22/05/2026.

Tarea : Unidad 1 A2: Investigación para la Evaluación y mejora del sistema de gestión de continuidad en ciberseguridad.

Maestría en Ciberseguridad.

ÍNDICE.

1. Portada.

2. Índice.

3. Introducción.

4. Objetivos de la evaluación y métodos.

5. Análisis de Riesgos y Hallazgos.

6. Recomendaciones de Mejora.

7. Conclusión.

8. Referencias Bibliográficas.

INTRODUCCIÓN.

La Universidad Digital de las Américas (UDA) es una institución de educación superior nativa digital que atiende a una matrícula activa de más de 5,000 estudiantes a través de programas académicos impartidos 100% en línea. La totalidad de sus operaciones académicas y administrativas se sustenta en un ecosistema tecnológico basado en la nube, el cual integra un Sistema de Gestión de Aprendizaje (LMS), un portal de facturación y un Sistema de Autenticación Única (SSO). Debido a esta dependencia absoluta de la infraestructura tecnológica, la disponibilidad, confidencialidad e integridad de sus servicios representan el núcleo de su viabilidad operativa y reputación institucional.

En respuesta al creciente volumen de ciberataques dirigidos al sector de la tecnología educativa (EdTech), la alta dirección de la UDA ha solicitado los servicios de consultoría externa especializada en ciberseguridad. El propósito de esta intervención es evaluar de manera exhaustiva el Sistema de Gestión de Continuidad de Negocio (SGCN) existente en la organización. A través de este informe, se analizarán las políticas actuales, los controles de seguridad y los planes de respuesta a incidentes, con el objetivo de identificar brechas críticas frente a los riesgos cibernéticos actuales y establecer recomendaciones estratégicas que fortalezcan la resiliencia tecnológica de la universidad.

Objetivos de la evaluación y métodos utilizados.

Objetivos de la Evaluación: El objetivo general de esta consultoría es evaluar la madurez, eficacia e idoneidad del Sistema de Gestión de Continuidad de Negocio (SGCN) y las prácticas de ciberseguridad de la Universidad Digital de las Américas (UDA).

De manera específica, la evaluación persigue los siguientes objetivos:

- Identificar y categorizar los riesgos de ciberseguridad que amenazan la infraestructura crítica de la UDA (LMS Canvas y Sistema SSO).
- Evaluar la solidez y actualización de las políticas de seguridad de la información y los planes de respuesta a incidentes (IRP) existentes.
- Determinar la eficacia de los controles de seguridad técnicos implementados frente a las amenazas contemporáneas del sector educativo.
- Detectar brechas de cumplimiento respecto a las mejores prácticas internacionales y emitir recomendaciones estratégicas para fortalecer la resiliencia tecnológica.

Métodos Utilizados Para cumplir con los objetivos trazados y asegurar una evaluación integral desde la perspectiva de gestión y defensa técnica (Blue Team), la consultoría se desarrolló utilizando las siguientes metodologías:

- 1º Revisión Documental (Auditoría de Escritorio):** Se ejecutó un análisis exhaustivo de la documentación que soporta el SGCN. Esto incluyó la revisión de las políticas de seguridad corporativas, el Plan de Recuperación ante Desastres (DRP), el Plan de Respuesta a Incidentes (IRP) y los manuales de procedimientos operativos. El objetivo fue verificar si la documentación está alineada con los riesgos actuales o si presenta obsolescencia.
- 2º Análisis de Brechas (Gap Analysis):** Se contrastó el estado actual de los procesos y controles de la UDA contra los marcos de referencia de la industria, específicamente tomando como base los controles de la norma ISO/IEC 27001 (Seguridad de la Información) y los lineamientos de continuidad de la norma ISO 22301.
- 3º Evaluación de Arquitectura y Controles de Seguridad:** Se realizó una revisión técnica de las configuraciones defensivas de la red y la nube, evaluando la robustez de los controles de acceso (MFA, segmentación de red), las políticas de copias de seguridad inmutables y la eficacia de los mecanismos de monitoreo de eventos de seguridad (SIEM/SOC).
- 4º Entrevistas Estructuradas:** Se simularon sesiones de entrevistas con el personal clave del departamento de Tecnologías de la Información y los responsables de la administración de la plataforma LMS, con el fin de validar el nivel de concientización y la comprensión real de los protocolos de emergencia documentados.

Análisis de Riesgos y Hallazgos de la Evaluación (Brechas Identificadas)

A partir de la revisión documental y técnica del Sistema de Gestión de Continuidad y las prácticas operativas de la Universidad Digital de las Américas (UDA), se ha identificado un nivel de madurez bajo en la postura de ciberseguridad. A continuación, se detallan las brechas críticas identificadas, su evaluación de riesgo y la justificación correspondiente:

1. Brecha en la Gestión de Identidades y Accesos (IAM)

- **Hallazgo:** Los sistemas críticos, incluyendo el acceso al portal del LMS (Canvas) y al Sistema de Autenticación Única (SSO), carecen de configuraciones de seguridad para las credenciales de los usuarios. No se exigen requisitos de complejidad (uso de caracteres especiales, mayúsculas, números), no existe un límite mínimo de longitud de caracteres y no se aplican políticas de caducidad o rotación de contraseñas.
- **Análisis de Riesgo e Impacto:** El riesgo es **Crítico**. Esta vulnerabilidad expone a la universidad a ataques de fuerza bruta, *credential stuffing* (re-lleno de credenciales) y secuestro de cuentas (*Account Takeover*). Si un atacante compromete una cuenta con privilegios administrativos debido a una contraseña débil, podría alterar calificaciones, robar datos personales o dar de baja los servicios en la nube, paralizando la continuidad académica.

2. Carencia de un Marco Normativo y Políticas de Seguridad Integral

- **Hallazgo:** Se detectó una severa escasez de políticas formales de seguridad de la información. La documentación actual es mínima y está enfocada casi exclusivamente en el control de activos físicos; por ejemplo, la única directriz clara establece que "para realizar el cambio de un equipo informático, este debe ser revisado y posteriormente autorizado por el departamento de Informática".
- **Análisis de Riesgo e Impacto:** El riesgo es **Alto**. La falta de políticas integrales (como políticas de uso aceptable, clasificación de la información o gestión de copias de seguridad) genera un vacío de gobernanza. Además, el hecho de que el departamento de Informática actúe simultáneamente como soporte técnico y como autorizador de auditoría de equipos evidencia una falta de **segregación de funciones**. Esto dificulta la rendición de cuentas y aumenta el riesgo de errores internos o fraude, afectando la resiliencia operativa.

3. Inmadurez en el Sistema de Gestión de Continuidad y Respuesta a Incidentes

- **Hallazgo:** Al revisar los elementos del sistema de continuidad, se descubrió que no existen Planes de Respuesta a Incidentes (IRP) documentados frente a amenazas cibernéticas (como infecciones por Ransomware o ataques DDoS). La respuesta actual ante problemas de TI recae en la improvisación del personal de soporte técnico.
- **Análisis de Riesgo e Impacto:** El riesgo es **Alto**. Sin un IRP o *Playbooks* específicos, el tiempo de contención de una amenaza se incrementa drásticamente. En caso de una caída de los servicios en la nube, el equipo técnico no tendrá un protocolo claro, lo que resultará en tiempos de inactividad que superarán cualquier Objetivo de Tiempo de Recuperación (RTO) aceptable para los estudiantes, impactando severamente la reputación de la UDA.

4. Ausencia de Cultura y Concientización en Ciberseguridad

- **Hallazgo:** No se encontraron registros ni programas activos de capacitación en ciberseguridad o simulacros de *phishing* dirigidos al personal administrativo, docente ni al alumnado.
- **Análisis de Riesgo e Impacto:** El riesgo es **Medio-Alto**. El factor humano sigue siendo el vector de ataque más explotado. Sin concientización, el personal y los estudiantes son altamente vulnerables a tácticas de ingeniería social, sirviendo como puerta de entrada para ataques que podrían comprometer toda la red institucional.

Recomendaciones de Mejora.

Con base en las brechas y riesgos críticos identificados durante la evaluación, se proponen las siguientes recomendaciones estratégicas y técnicas para robustecer el Sistema de Gestión de Continuidad en Ciberseguridad de la Universidad Digital de las Américas (UDA). Estas acciones están priorizadas para mitigar las vulnerabilidades más urgentes a corto y mediano plazo:

1. Fortalecimiento de la Gestión de Accesos (IAM) e Identidades:

- **Recomendación:** Implementar de manera inmediata una política estricta de contraseñas en el Directorio Activo y en el SSO, exigiendo una longitud mínima (ej. 12 caracteres), complejidad alfanumérica y un ciclo de rotación de 90 días.
- **Medida Técnica Complementaria:** Desplegar Autenticación Multifactor (MFA) obligatoria en todos los accesos a la plataforma Canvas y al SSO. Se debe priorizar el despliegue en cuentas con privilegios administrativos y docentes, escalando posteriormente al alumnado.
- **Justificación:** La implementación de MFA mitiga en más de un 90% el éxito de ataques por compromiso de credenciales. Al robustecer la puerta de entrada, se protege la integridad de los datos académicos y la disponibilidad del servicio, reduciendo drásticamente el riesgo de un secuestro de cuentas.

2. Desarrollo del Marco Normativo y Gobernanza de Seguridad

- **Recomendación:** Diseñar, aprobar y difundir un cuerpo normativo integral de ciberseguridad. Este debe incluir, como mínimo: Política de Control de Accesos, Política de Gestión de Copias de Seguridad y Política de Clasificación de la Información.
- **Medida Estructural:** Aplicar el principio de Segregación de Funciones (SoD) dentro de la estructura de TI. El área operativa de soporte técnico debe separarse de las funciones de auditoría y autorización de cambios en la infraestructura.
- **Justificación:** Un marco normativo formaliza las "reglas del juego" y elimina la toma de decisiones improvisada. La segregación de funciones es un control preventivo crítico que reduce la posibilidad de errores no detectados o de uso malintencionado de los recursos internos.

3. Formalización del Plan de Respuesta a Incidentes (IRP)

- **Recomendación:** Desarrollar un Plan de Respuesta a Incidentes (IRP) formal, definiendo un Equipo de Respuesta a Emergencias Informáticas (CERT/CSIRT) interno con roles claramente asignados (Ej. Líder de Incidente, Especialista de Contención, Enlace de Comunicación).
- **Medida Técnica Complementaria:** Crear *Playbooks* (guías de acción paso a paso) específicos para las amenazas de mayor impacto para la UDA: Ataque de Ransomware y Ataque de Denegación de Servicio (DDoS).
- **Justificación:** Ante un evento disruptivo, el tiempo de reacción es el factor que determina si se cumple o no con el Objetivo de Tiempo de Recuperación (RTO). Tener un proceso documentado evita el pánico, agiliza la contención técnica y garantiza la continuidad académica en el menor tiempo posible.

4. Implementación de un Programa de Cultura y Concientización

- **Recomendación:** Desplegar un programa continuo de "Security Awareness" obligatorio para todo el personal administrativo y docente.
- **Medida Técnica Complementaria:** Ejecutar campañas trimestrales de simulación de *phishing* (mediante herramientas controladas) para medir el nivel de alerta del personal y focalizar capacitaciones en usuarios reincidentes.
- **Justificación:** El factor humano es el principal vector de entrada para los ciberataques actuales. Transformar a los empleados en la primera línea de defensa es una de las estrategias de mitigación de riesgos con mejor retorno de inversión, asegurando así la sostenibilidad a largo plazo del SGCN.

CONCLUSIÓN.

La evaluación del Sistema de Gestión de Continuidad en Ciberseguridad de la Universidad Digital de las Américas (UDA) ha puesto en evidencia que, a pesar de operar bajo un modelo de negocio nativo digital, la institución presenta brechas críticas en su postura defensiva. La dependencia absoluta de plataformas tecnológicas como el LMS y el Sistema de Autenticación Única (SSO) contrasta significativamente con la actual carencia de controles técnicos robustos, marcos normativos formales y planes de respuesta a incidentes documentados.

Las vulnerabilidades identificadas —que abarcan desde la debilidad en la gestión de identidades y accesos, hasta la ausencia de segregación de funciones y de una cultura de concientización— exponen a la universidad a riesgos cibernéticos de alto impacto. Una materialización de amenazas como el secuestro de cuentas o ataques de *Ransomware* paralizaría de inmediato la operación académica, comprometiendo la integridad de los datos y dañando severamente la reputación institucional.

No obstante, las recomendaciones estratégicas planteadas en este informe proporcionan una hoja de ruta clara, realista y accionable para mitigar dichos riesgos. Al transitar hacia la implementación de controles preventivos técnicos (como la Autenticación Multifactor), la formalización de políticas de seguridad y el desarrollo de un Equipo de Respuesta a Emergencias Informáticas (CERT interno), la UDA logrará cerrar las brechas operativas. En última instancia, esta evolución permitirá a la universidad pasar de una postura reactiva y vulnerable frente a incidentes aislados, a un estado de resiliencia proactiva, garantizando la continuidad de sus servicios educativos frente a las constantes interrupciones del entorno digital.

REFERENCIAS BIBLIOGRÁFICAS.

- Organización Internacional de Normalización (ISO). (2022). *ISO/IEC 27001:2022 Seguridad de la información, ciberseguridad y protección de la privacidad — Sistemas de gestión de la seguridad de la información — Requisitos*. Ginebra, Suiza.
- Organización Internacional de Normalización (ISO). (2019). *ISO 22301:2019 Seguridad y resiliencia — Sistemas de gestión de la continuidad del negocio — Requisitos*. Ginebra, Suiza.
- Instituto Nacional de Estándares y Tecnología (NIST). (2012). *Computer Security Incident Handling Guide* (NIST Special Publication 800-61, Revision 2). Departamento de Comercio de los Estados Unidos.